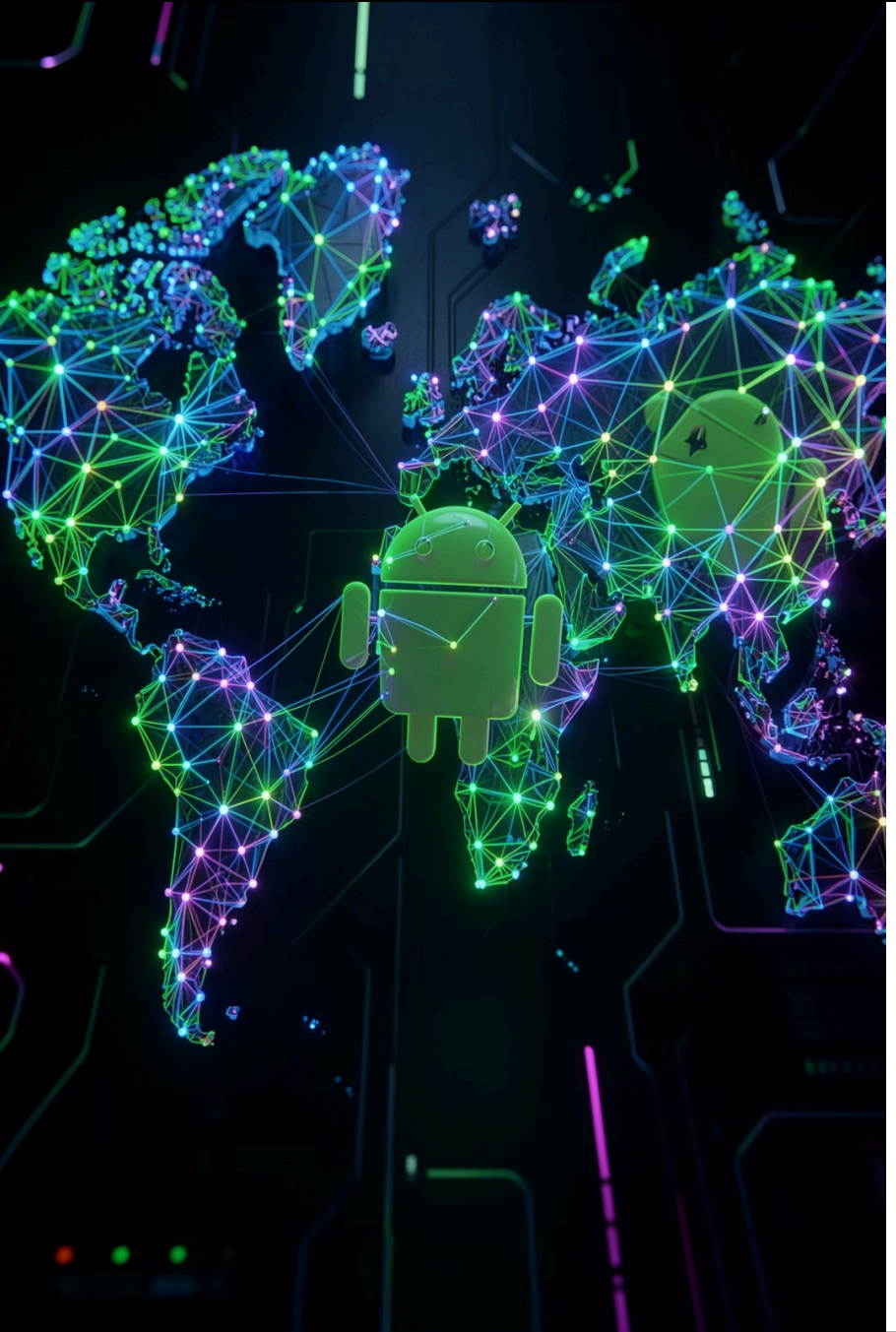
Sécurité des Systèmes Android

Anatomie des Vulnérabilités Majeures & Mécanismes d'Exploitation

Vincent Florella · Thomas Rinto · Noureddine Stamboul· Bilel Amriche—
M2 E3IN Cybersécurité — ESIEE-IT 2025/2026

Made with GAMMA



Android : une cible de choix

71%

Parts de marché mondial

Android domine le marché mobile mondial en 2024, exposant des milliards d'appareils.

5

Vulnérabilités analysées

BlueFrag, Badspin, SpinOk, FluBot, Hermit — cinq vecteurs d'attaque critiques.

16

Semaines de délai max

Fragmentation OEM : délais de patch critiques de 4 à 16 semaines selon les constructeurs.

Des milliards d'appareils actifs exposent quotidiennement des données personnelles, bancaires et professionnelles. La fragmentation des constructeurs OEM crée des fenêtres de vulnérabilité critiques difficiles à combler.

Made with GAMMA

Architecture de sécurité Android

Les piliers de la sécurité Android

Sandbox applicative

Chaque application tourne dans un processus isolé avec un UID Unix dédié, limitant les interactions inter-processus.

Permissions Runtime

Modèle de permissions granulaires depuis Android 6 — l'utilisateur accorde les droits à la demande.

SELinux Enforcing

Actif depuis Android 5 — contrôle d'accès obligatoire limitant les actions des processus compromis.

Google Play Protect & Verified Boot

Chaîne de confiance cryptographique + bulletins de sécurité mensuels classés Critical / High / Moderate / Low.

Made with GAMMA

CVE-2020-0022 · CVSS 8.8

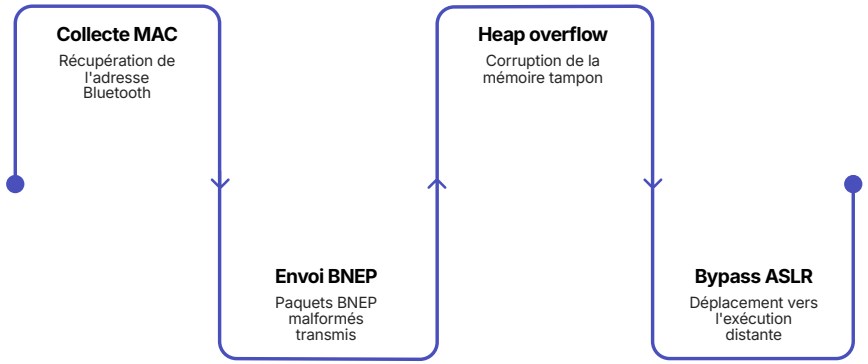
BlueFrag — RCE Bluetooth Zero-Click

Mécanisme d'exploitation

Découvert par : Inbar Raz — ERNW Research · Janvier 2020

Heap overflow dans le protocole BNEP (Bluetooth Network Encapsulation Protocol). Aucun couplage requis — portée d'attaque d'environ 10 mètres. Affecte Android 8.0 et 8.1 avec RCE complète. Sur Android 9+, le CFI actif limite l'impact à un simple DoS.

Chaîne d'exploitation



Remédiation & Patchs

01

Google — Février 2020

Correctif intégré dans le bulletin de sécurité Android (patch level 2020-02-01) — correction du calcul de taille des paquets BNEP.

02

Samsung — Mars 2020

Patch déployé pour Galaxy S8 / S9 / S10 via mise à jour OTA.

03

Huawei — Avril 2020

Correctif intégré pour les appareils encore sous support actif.

04

Xiaomi — Délai variable

Certains appareils entrée de gamme n'ont jamais reçu le patch. Recommandation : désactiver le Bluetooth hors usage, éviter le mode découvrable en public.

Made with GAMMA

CVE-2022-20421 · CVSS 7.8

Badspin — Élévation de Privilège Kernel

Analyse technique

Découvert par : Aman Panda — Microsoft Security Response Center (MSRC) · Septembre 2022

Use-After-Free dans le driver Binder IPC — le mécanisme central de communication inter-processus Android. Une race condition permet un heap spray conduisant à un accès lecture/écriture kernel, puis à l'obtention des droits root avec bypass complet de SELinux. Affecte Android 10 à 12L.

⚠ Les appareils Android 10 sans support fabricant restent toujours vulnérables — aucun correctif disponible.

Remédiation & Patchs

Google — Octobre 2022

Bulletin Android (patch level 2022-10-05) — ajout de vérifications atomiques et verrous correctement scoped sur le Binder.

Google Pixel

Correctif immédiat avec la mise à jour OTA d'Octobre 2022.

Samsung — Novembre 2022

Intégré dans les Samsung Security Updates pour Galaxy S21 / S22 / A53. Délai moyen OEM : 4 à 8 semaines.

Mitigations complémentaires

Samsung RKP (Real-time Kernel Protection) et CFI réduisent significativement l'exploitabilité.

Made with GAMMA

SUPPLY CHAIN ATTACK · +420M TÉLÉCHARGEMENTS

SpinOk SDK & FluBot — Menaces Écosystème

SpinOk — Attaque Supply Chain

Mai 2023 · Dr. Web

SDK marketing légitime en apparence infiltrant plus de 100 applications sur le Play Store. Vol du presse-papier, exfiltration de fichiers, détection d'émulateurs, C2 chiffré. Plus de 420 millions de téléchargements affectés.

Google a supprimé les 100+ applications en 72h. Play Protect mis à jour pour détecter les signatures SpinOk. L'App Defense Alliance a introduit un scan systématique des SDK tiers.

FluBot — Trojan Bancaire Smishing

Décembre 2020 · ThreatFabric & PRODAFT

Smishing DHL / FedEx / La Poste → APK sideloadé → Accessibility Services → overlay attacks. 340+ applications bancaires ciblées dans 12+ pays. Auto-propagation via carnet d'adresses, DGA C2.

Démantèlement Europol en Mai 2022 — opération coordonnée entre 11 pays. Android 13 bloque nativement ce vecteur via restriction des Accessibility Services pour APK sideloadés.

Made with GAMMA

CVSS 9.8 · CRITICAL

Hermit — Spyware Étatique RCS Lab

Profil de la menace

Découvert par : Google Threat Analysis Group (TAG) & Lookout Security · Juin 2022

RAT commercial développé par RCS Lab (Milan, Italie), déployé contre des journalistes, activistes et opposants politiques au Kazakhstan, en Italie et au Myanmar. Chaîne d'exploitation : drive-by Chrome 0-day + CVE-2021-1048 Exynos → root → accès Signal / WhatsApp / Telegram.

Score CVSS 9.8 — chaîne d'exploits kernel multi-composants. Exploité en 0-day avant toute divulgation publique.

Remédiation multi-composants

Google — Notification d'urgence

Correctifs intégrés hors cycle pour Android et Chrome dès la découverte.

CVE-2021-1048 — Novembre 2021

Corrigé dans le bulletin Android — exploité en 0-day avant divulgation publique.

Samsung — Drivers GPU Exynos

Correctifs d'urgence publiés dans les semaines suivant la divulgation.

Google Chrome — Février 2022

Patch CVE-2022-0609 (0-day renderer) déployé en urgence.

Recommandations cibles à risque

Mode Lockdown (Android 12+), Pixel avec Android Enterprise, vérification régulière des processus actifs. RCS Lab ajouté à la liste CSV de Google TAG.

Made with GAMMA

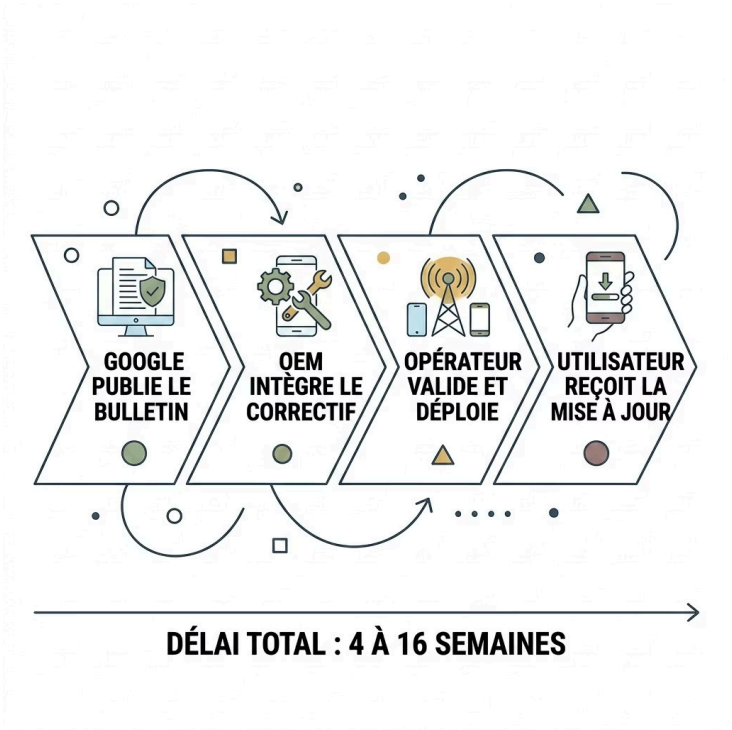
Analyse Comparative des 5 Vulnérabilités

Vulnérabilité	CVSS	Type	Impact	Remédiation
BlueFrag (jan. 2020 — ERNW)	8.8	RCE Bluetooth zero-click	Exécution de code à distance sans interaction	Patch Google fév. 2020 — OTA Samsung mars 2020
Badspin (sept. 2022 — MSRC)	7.8	EoP kernel UAF	Root + bypass SELinux complet	Patch Google oct. 2022 — délai OEM 4-8 semaines
SpinOk (mai 2023 — Dr. Web)	N/A	Supply chain SDK	420M victimes — vol données, exfiltration	Suppression Play Store 72h — scan ADA
FluBot (déc. 2020 — ThreatFabric)	N/A	Smishing viral	340+ apps bancaires ciblées — 12+ pays	Démantèlement Europol mai 2022
Hermit (juin 2022 — Google TAG)	9.8	Spyware étatique 0-days	RAT complet — journalistes, activistes	Patches d'urgence multi-composants hors cycle

⚠ Tendance majeure : supply chain et spywares étatiques en forte hausse — remédiation de plus en plus complexe et multi-acteurs.

Made with GAMMA

Le Problème de la Fragmentation Android



Solutions en cours de déploiement

1

Project Mainline

Mise à jour directe des modules critiques via Play Store sans passer par l'OEM — contourne le pipeline traditionnel.

2

MTE (ARM v9)

Détection hardware des bugs mémoire — Use-After-Free et débordements détectés au niveau matériel.

3

Android 13+

Blocage du sideloading des Accessibility Services — aurait nativement bloqué FluBot.

4

Android 14/15

Restrictions Intent, Privacy Sandbox, améliorations structurelles continues — mais insuffisantes pour les appareils abandonnés.

⊗ Des millions d'appareils sous Android 8/9/10 ne recevront jamais de correctif — fin de support OEM définitive.

Made with GAMMA

Recommandations & Conclusion

Pour les utilisateurs

Mises à jour automatiques

Activer les mises à jour systématiques et automatiques sans délai.

Pas d'APK hors Play Store

Ne jamais installer d'application en dehors du Play Store officiel.

Bluetooth & Smishing

Désactiver le Bluetooth hors usage. Méfiance absolue envers les SMS avec lien.

Accessibility Services

Refuser les Accessibility Services aux applications non critiques.

Pour les entreprises

> Android = écosystème dominant mais structurellement fragmenté. Le correctif existe toujours — le problème est sa distribution. Android 14/15 + Project Mainline représentent des progrès réels, mais insuffisants pour les appareils abandonnés.

Vincent Florella · Thomas Rinto · Noureddine Stamboul · Bilel Amriche— *M2 E3IN Cybersécurité — ESIEE-IT 2025/2026*

MDM obligatoire

Microsoft Intune, VMware Workspace ONE — forcer le niveau de patch minimum sur tous les appareils du parc.

MTD — Mobile Threat Defense

Lookout, Zimperium, Pradeo — détection comportementale des menaces mobiles en temps réel.

Politique BYOD

Inventaire complet et niveau de patch minimum requis pour tout appareil personnel accédant aux ressources entreprise.

Formation collaborateurs

Sensibilisation régulière au smishing et à l'ingénierie sociale — le maillon humain reste le plus exploité.

Made with GAMMA